

PROCEDIMIENTO DE SEGURIDAD EN EL DESARROLLO DE APLICACIONES

1. OBJETIVO

Establecer los lineamientos y actividades necesarias para garantizar la seguridad de las aplicaciones y sistemas desarrollados o adquiridos por CESVI México, asegurando la **confidencialidad, integridad y disponibilidad** de la información tratada, en cumplimiento con la **Política de Seguridad de la Información** y los **controles 8.26 a 8.34 de la norma ISO/IEC 27001:2022**.

2. ALCANCE

Este procedimiento aplica a todo el **ciclo de vida del desarrollo de software** de CESVI México, desde la planeación, diseño, desarrollo, pruebas, implementación, mantenimiento y baja, incluyendo desarrollos **internos y externos**, y los **ambientes** de:

- **Desarrollo local (localhost)**
- **Preproducción (appweb-dev.cesvimexico.com.mx)**
- **Producción (appweb.cesvimexico.com.mx)**

3. REFERENCIAS

- ISO/IEC 27001:2022, Controles 8.26–8.34
- Política de Seguridad de la Información CESVI
- OWASP ASVS v4.0.3
- OWASP ZAP
- Guía de Desarrollo Seguro CESVI (Template Dynamic)
- Manual de Control de Versiones y Despliegue (GitHub Actions + SonarQube)

4. RESPONSABLES

Rol	Responsabilidades
DTI (Desarrollador de TI)	Aplicar el procedimiento, usar plantillas seguras, realizar pruebas OWASP y SonarQ, mantener control de versiones.
Administrador de Repositorios	Crear repositorios, ramas y configurar flujos CI/CD.
Líder de Proyecto / Product Owner	Validar requerimientos, coordinar entregas y aceptación.
Responsable de Seguridad de la Información (RSI)	Supervisar cumplimiento y validar evidencias de seguridad.

Proveedores Externos

Cumplir con este procedimiento y entregar resultados de pruebas aprobadas.

5. DESARROLLO DEL PROCEDIMIENTO

5.1 (Control 8.25) Ingeniería segura

5.1 (Control 8.25, Control 8.26) Ingeniería segura Y Seguridad en el desarrollo de software y sistemas

- Se debe registrar en el **catálogo de proyectos SGSI** para mantener la trazabilidad y seguimiento en el SIC 2.0.
- **Todo proyecto debe documentarse mediante un Formato de Requerimientos Funcionales y Técnicos**, donde se define:
 - El **propósito del sistema**, usuarios objetivo, criticidad de datos, infraestructura requerida y dependencias.
 - Realizar un Análisis de Riesgos de Seguridad del Software, documentando amenazas, impactos y controles (ver Matriz de Riesgos).
- **Se requiere documentación técnica mínima:**
 - Diagrama de arquitectura
 - **Diagrama de flujo de datos**
 - **Reglas de negocio y validaciones**
 - **Controles de seguridad implementados**
- El RSI validará el alcance del proyecto y de esta manera revisará si la arquitectura e infraestructura cumple con los requisitos del desarrollo.
- Definir los **roles y permisos** de los participantes.
- Se utilizará la **arquitectura corporativa aprobada (Template Dynamic)**:
 - **ReactJS (Front-End)**
 - **Laravel/Lumen (Back-End)**
 - **MySQL (DB)**
 - **Keycloak (Gestión de identidades y acceso)**
- Toda librería o dependencia externa debe provenir de fuentes oficiales (npm, composer) y mantenerse actualizada.

5.2 (Control 8.27) Pruebas de seguridad en el desarrollo y aceptación

- Las pruebas de seguridad deben realizarse antes de liberar cualquier versión a producción.
- Tipos de pruebas:
 1. **SonarQube (análisis estático de código)** – ejecutado en GitHub Actions, el cual te genera sugerencias para optimizar el código de forma automatizada (estas pruebas incluyen la revisión de código por pares)
 2. **OWASP ZAP (análisis dinámico de vulnerabilidades web).**
 3. **Checklist OWASP ASVS CESVI** – aplicado según criticidad.
- Los resultados se almacenan en **SIC 2.0**, y se deben corregir todas las vulnerabilidades **altas o críticas** antes de aprobación.
- Toda versión debe incluir una **evidencia de prueba de aceptación firmada** por el Product Owner y el RSI.

5.3 (Control 8.28) Protección de datos en entornos de prueba

- Está **prohibido** el uso de información personal o datos sensibles reales.
- Los datos deben anonimizarse o generarse sintéticamente.
- Accesos a entornos de prueba y preproducción restringidos a personal DTI autorizado.
- Los respaldos o dumps de producción no podrán copiarse a otros entornos sin aprobación del RSI.

Falta por incorporar:

- Política formal de anonimización de datos y plantilla de autorización.

5.4 (Control 8.29) Externalización del desarrollo

- Los proveedores deben firmar un **Acuerdo de Confidencialidad (NDA)** y aceptar el cumplimiento del presente procedimiento.
- Se les debe entregar este documento como guía obligatoria.
- Ninguna entrega será aceptada sin:
 - Reporte OWASP ZAP
 - Resultado SonarQube
 - Checklist ASVS aprobado
- Los contratos deben incluir cláusulas de seguridad y propiedad del código.

5.5 (Control 8.30) Pruebas de seguridad tras cambios

- Todo cambio de código, librería o infraestructura debe pasar por pruebas OWASP ZAP y SonarQube antes del despliegue.
- El proceso de GitHub Actions debe incluir validaciones automáticas que impidan merges sin pruebas exitosas.
- Cualquier cambio mayor (versión) requiere nueva validación del RSI.
- Una vez desplegada a producción en el SIC 2.0 se registrada la versión.

5.6 (Control 8.31) Principios de ingeniería segura

- Se aplican los principios de **defensa en profundidad, mínimo privilegio, seguridad por diseño y separación de ambientes**.
- El Template Dynamic incluye:
 - Autenticación centralizada con Keycloak.
 - Cifrado HTTPS.
 - Validación de entrada/salida.
 - Tokens de sesión con expiración.
 - Restricciones de acceso por permisos a cada usuario.
- Se realizan **revisiones de arquitectura** antes del despliegue de nuevos módulos.
- Para las aplicaciones los requisitos mínimos requeridos son los siguientes:

Tipo de Sistema

Requisitos de Seguridad Base

Aplicaciones Web (React/Laravel)

- Autenticación con Keycloak.
- HTTPS obligatorio.
- Validación de entradas.
- Control de roles y permisos.
- Escaneo OWASP ZAP antes de producción.

APIs REST (Lumen/Laravel)

- Autenticación por token JWT.
- Control de CORS.
- Límite de peticiones (rate limit).
- Logs centralizados.

Bases de datos

- Acceso restringido (solo backend).
- Cifrado en reposo.
- Copias de respaldo automáticas.
- No almacenar contraseñas en texto plano.

Aplicaciones móviles

- Cifrado local.
- Validación de certificados.

Tipo de Sistema

Requisitos de Seguridad Base

Sistemas en nube (Azure)

- No almacenar claves ni credenciales en el dispositivo.
- Acceso por VPN.
- Cifrado en tránsito y reposo.
- Backup automático.
- Control de identidades y roles RBAC.

✓ Falta por incorporar:

- Modelo formal de amenazas (Threat Modeling).

5.7 (Control 8.32) Programación segura

- Todos los desarrolladores deben seguir las **Guías de Codificación Segura CESVI**, basadas en OWASP Top 10.
- Se debe:
 - Usar variables de entorno en .env.
 - Validar datos del cliente y sanitizar.
 - Controlar errores sin mostrar detalles.
 - Proteger sesiones y cookies.
 - Evitar almacenamiento local de contraseñas.
- El DTI realiza revisiones de seguridad del código antes de liberar a preproducción.
- El DTI tendrá que revisar las nuevas versiones de las librerías que utiliza la Temple Dinamyc con la finalidad de mantener actualizada la plantilla. De la mano tendrá que tener una programación de capacitación segura anual, estos puntos revisados en el SIC 2.0

5.8 (Control 8.33) Gestión de vulnerabilidades técnicas

- Toda vulnerabilidad identificada en SonarQube o ZAP debe registrarse en **SIC 2.0**.
- Se evalúa con base en **CVSS v3** y se clasifica en crítica, alta, media o baja.
- Las vulnerabilidades críticas se corrigen antes del despliegue.
- RSI da seguimiento y valida la corrección.

✓ Falta por incorporar:

- Integrar escaneo automatizado semanal (ZAP CLI o Dependabot).

5.9 (Control 8.34) Verificación y validación de la seguridad de los sistemas

- El RSI verifica que todos los controles aplican antes de liberar un sistema a producción.
- Se genera un **Acta de Validación de Seguridad de Aplicaciones**, con resultados de pruebas y evidencia de cumplimiento.
- El Product Owner firma la aceptación formal.

Falta por incorporar:

- Procedimiento de revalidación periódica de aplicaciones productivas.

6. REGISTROS Y EVIDENCIAS

(Misma tabla anterior, más el Acta de Validación y Reporte de Vulnerabilidades)

7. ANEXOS

1. Formato de Requerimientos de Desarrollo Seguro
2. Plantilla OWASP Checklist CESVI
3. Guía OWASP ASVS
4. Acta de Validación de Seguridad
5. Guía Template Dynamic CESVI

8. MEJORA CONTINUA

Este procedimiento será revisado **anualmente o ante cada cambio significativo** en las tecnologías utilizadas, normativas de seguridad o hallazgos de auditoría interna o externa.